

NIMBUSGUARD TECHNOLOGIES, INC.

Vendor and Supply Chain Management Policy

Third-Party Risk Assessment, Monitoring & Sub-Processor Controls

Document ID:	NG-VSM-008	Version:	2.3
Effective Date:	February 15, 2026	Owner:	General Counsel – Rachel Torres
Classification:	Internal – Confidential	Status:	Approved

1. Third-Party Risk Assessment

All vendors and service providers that access, process, store, or transmit NimbusGuard data or connect to NimbusGuard systems must undergo a security risk assessment prior to engagement. The assessment is tiered based on data sensitivity and criticality:

Vendor Tier	Criteria	Assessment
Critical	Processes Restricted data; provides core infrastructure services	First-party questionnaire, SOC 2 review, penetration test report review, on-site
High	Processes Confidential data; provides business critical services	Self-reported questionnaire, SOC 2 or ISO 27001 review, evidence of pen test
Medium	Accesses Internal data; provides support services	Self-reported security questionnaire, certification review
Low	No data access; commodity services	Contractual security terms only

2. Sub-Processor List

NimbusGuard maintains a public sub-processor list (available at nimbusguard.io/sub-processors) and provides 30 days' advance notice before engaging a new sub-processor. Current critical and high-tier sub-processors:

Sub-Processor	Service	Data Processed	Location
Amazon Web Services	Cloud hosting, storage, compute	All customer data	US, EU
Okta	Identity provider (internal)	Employee identity data	US
Splunk	SIEM and log management	System and security logs	US
CrowdStrike	Endpoint detection & response	Endpoint telemetry	US
Stripe	Payment processing	Billing data (PCI scope)	US
Twilio/SendGrid	Transactional email	Email addresses, notification content	US
Snowflake	Data warehouse (analytics)	Anonymized usage data	US, EU
PagerDuty	Incident alerting	Incident metadata	US

3. Ongoing Monitoring

Critical and High tier vendors are monitored continuously using SecurityScorecard for external risk posture monitoring and required to provide updated SOC 2 Type II or ISO 27001 reports annually. Vendor risk reassessments are performed: annually for Critical and High tiers; biennially for Medium tier; and upon contract renewal for Low tier. Vendors are contractually obligated to notify NimbusGuard of any security incidents affecting NimbusGuard data within 24 hours.

4. Contractual Security Requirements

All vendor contracts include the following security provisions: data processing agreement (DPA) with Standard Contractual Clauses where applicable; right to audit clause; security incident notification requirements (24-hour SLA); data return and deletion obligations upon termination; minimum insurance requirements (cyber liability, professional liability); compliance with NimbusGuard's Vendor Code of

Conduct; and subcontractor approval requirements.

5. Software Supply Chain Security

NimbusGuard secures its software supply chain through:

- Software Bill of Materials (SBOM) generated for every release using Syft (SPDX format)
- All third-party dependencies are scanned continuously by Snyk for known vulnerabilities
- Container base images are sourced from a curated internal registry, rebuilt weekly from upstream, and signed using Cosign (Sigstore)
- Git commits require GPG signing, and all CI/CD pipelines enforce provenance attestation (SLSA Level 3)
- Open source license compliance is enforced via FOSSA